

Backlog actualizado de tareas - Auditoria de Ciberseguridad Partilot

Version revisada: se han añadido incidencias detectadas en las fases que no estaban incluidas en la primera tabla. Se mantiene el mismo formato de columnas solicitado.

ID	Prioridad	Fase	Categoría	Problema detectado	Tarea de desarrollo
SEC-001	Crítica	F1	Upload / RCE	Subida de archivos arbitraria en administración: el parámetro image se almacena en public/images/ sin validar MIME ni extensión, permitiendo subir un .php malicioso.	Validar MIME real, extensión y contenido; renombrar ficheros; almacenar fuera de public si aplica; bloquear ejecución de scripts en directorios de subida.
SEC-002	Alta	F2	Credenciales	Contraseña provisional fija 12345678 para gestores de entidad.	Generar contraseñas aleatorias de un solo uso, forzar cambio en primer acceso y caducar invitaciones/tokens.
SEC-003	Media	F2	Auditoría	Ausencia de logs de auditoría en cambios de estado y permisos de gestores.	Registrar quién, cuándo, IP, user-agent, valor anterior y valor nuevo en acciones de gestores/permisos.
SEC-004	Media	F2	Fiscal / Identidad	El NIF/CIF puede quedar nullable al actualizar una entidad activa.	Hacer obligatorio NIF/CIF válido para entidades activas y bloquear guardado si se elimina el identificador fiscal.
SEC-005	Alta	F2	XSS	Stored XSS en notas/comentarios de entidad al guardar HTML sin sanitizar.	Sanear entradas, escapar salida en vistas y aplicar whitelist/purificador HTML donde proceda.
SEC-006	Crítica	F3	XML / XXE	Importación XML con simplexml_load_file() sin deshabilitar entidades externas.	Configurar libxml de forma segura, deshabilitar entidades externas, validar esquema XML y limitar rutas/URLs permitidas.
SEC-007	Alta	F4	Integridad	Colisión potencial de referencias limitadas a 9999 mediante min(9999, ...).	Rediseñar generación de referencias para garantizar unicidad sin límite práctico; usar IDs completos, ULID/UUID o secuencia fuerte.
SEC-008	Alta	F4	QR / Firma	URLs de QR sin firma criptográfica.	Añadir HMAC/firma digital a la URL y validar firma, expiración y pertenencia antes de procesar.
SEC-009	Media	F4	Trazabilidad física	Posible duplicidad de talonarios físicos al no existir serialización/hash de impresión.	Añadir identificador único de impresión, hash por taco/participación y registro de escaneos para detectar copias.
SEC-010	Media	F5	Credenciales	Política débil de contraseñas en autorregistro: mínimo de 6 caracteres.	Exigir mínimo 8-12 caracteres, comprobación contra contraseñas comunes y política de robustez razonable.
SEC-011	Alta	F5	SMS / Fuerza bruta	Endpoint de validación SMS sin rate limiting.	Añadir rate limit por IP, teléfono, usuario y ventana temporal; bloquear tras intentos fallidos y registrar abuso.
SEC-012	Media	F5	Duplicidad email	Consulta de duplicidad sensible a mayúsculas/minúsculas.	Normalizar emails en minúsculas, índice único case-insensitive y migración de duplicados existentes.
SEC-013	Media	F5	RGPD	No se guarda log explícito de aceptación de términos/privacidad con IP, timestamp y versión.	Crear tabla de consentimientos con versión legal, IP, user-agent, fecha/hora y hash del texto aceptado.
SEC-014	Media	F5	Comunicaciones	Correos de registro de compradores aparecen como no enviados/interceptados no enviados.	Revisar flujo de envío de correo de registro/confirmación para compradores y añadir alertas si falla.
SEC-015	Media	F6	Credenciales vendedores	Ausencia de política de contraseñas seguras y cambio obligatorio inicial para vendedores.	Aplicar política de contraseña, caducidad de contraseña provisional y cambio obligatorio al vincular vendedor.
SEC-016	Media	F6	Identidad fiscal	Vendedores externos pueden registrarse con NIF/CIF nulo o vacío.	Hacer NIF/CIF obligatorio para vendedores físicos/externos y validar documento antes de permitir ventas.
SEC-017	Media	F6	Trazabilidad adjudicación	No se guarda instantánea histórica de condiciones de donativo al adjudicar tacos.	Persistir snapshot de tarifas, donativo, comisión, entidad, vendedor y condiciones en el momento de adjudicación.
SEC-018	Alta	F7	Conciliación pagos	Falta conciliación automática en tiempo real entre pasarela/Stripe e inventario vendido.	Implementar conciliación de doble entrada: pago confirmado, cambio de estado, recibo y compensación automática si falla.
SEC-019	Media	F7	Caja manual	Liquidaciones físicas permiten efectivo/transferencia sin justificante ni firma del gestor principal.	Exigir justificante digital, aprobación/firma del responsable y log inmutable de cierre de caja.
SEC-020	Media	F7	RGPD venta directa	Compra directa sin log explícito de aceptación de términos.	Registrar aceptación de condiciones por comprador con IP, fecha, versión e identificador de operación.
SEC-021	Control	F7/F8	Codificación	La auditoría indica Codificación UTF-8 correcta, pero conviene dejarlo como prueba regresiva permanente para evitar caracteres corruptos en nombres, notas y correos.	Añadir test automatizado de UTF-8/charset en BD, PDFs, emails y exportaciones; bloquear guardado si hay caracteres no válidos.

ID	Prioridad	Fase	Categoría	Problema detectado	Tarea de desarrollo
SEC-022	Alta	F8	Stock físico	Conversión automática de stock físico flotante a ventas si no se devuelve explícitamente.	Separar estados vendido/devuelto/extraviado/pendiente; no convertir a vendido sin cobro real y conciliación.
SEC-023	Media	F8	Alertas stock	No hay alertas en tiempo real por stock pendiente de devolución.	Notificar a gestores cuando haya stock flotante, descuadres o cierres incompletos.
SEC-024	Alta	F8	Integridad stock	Falta validación de devolución de participaciones ya vendidas.	Bloquear devoluciones de participaciones vendidas/cobradas y validar transición de estado en backend.
SEC-025	Alta	F8	Contabilidad	Auditoría contable de Fase 8 marca error de consistencia detectado.	Revisar diferencias entre participaciones disponibles, vendidas, devoluciones y liquidaciones; crear reconciliación automática.
SEC-026	Media	F8	Comunicaciones	Correos de liquidación/devolución aparecen como no enviados en múltiples registros.	Revisar cola/mailers, reintentos, logging y alertas de fallo en correos de cierre.
SEC-027	Alta	F9	Negocio / Inventario	Uso de round() en vez de ceil() genera déficit de décimos y participaciones huérfanas.	Sustituir por ceil(), recalcular reservas afectadas y validar respaldo físico antes de ventas/cierre.
SEC-028	Crítica	F10	Rendimiento / Memoria	Defecto crítico de consumo de memoria en escrutinio/premios.	Procesar escrutinio por lotes/chunks, paginar consultas, evitar carga masiva en memoria y añadir pruebas de volumen.
SEC-029	Crítica	F11	Solvencia	No se descuenta remaining_prize_funds tras retiro exitoso; posible replay financiero.	Decremento atómico dentro de transacción, idempotency key, bloqueo por estado y auditoría de retirios.
SEC-030	Crítica	F12	Stripe / Imprenta	Underpayment: pago incompleto aceptado en orden de impresión.	Calcular importe en servidor, comparar con PaymentIntent confirmado y rechazar discrepancias.
SEC-031	Crítica	F12	SQL Injection	SQL Injection en notas de orden de impresión.	Usar consultas parametrizadas/ORM, validación y escaping; prohibir SQL dinámico con entrada de usuario.
SEC-032	Crítica	F12	XSS	Stored XSS en nombre de peña/orden de diseño.	Sanear campos, escapar en renderizado y aplicar Content Security Policy.
SEC-033	Crítica	F12	Upload	Null Byte en subida de ficheros de diseño.	Normalizar nombre, validar extensión/MIME real, antivirus si aplica y rechazar bytes nulos.
SEC-034	Crítica	F12	Rate limit	Fuerza bruta al endpoint de verificación de estados de Stripe.	Rate limit, captcha/lockout si aplica y logs de abuso.
SEC-035	Crítica	F12	Autenticación	Solicitudes de impresión sin JWT activo.	Middleware obligatorio de autenticación y pruebas negativas de endpoints.
SEC-036	Crítica	F12	IDOR	Consulta de estados de órdenes de impresión ajenas.	Comprobar ownership/tenant en cada consulta y usar políticas de autorización.
SEC-037	Crítica	F12	Webhook Stripe	Modificación del email de éxito en request/webhook.	Ignorar datos manipulables del cliente y verificar firma oficial de Stripe.
SEC-038	Crítica	F12	Permisos	Bypass de firma de supervisor en órdenes de impresión > 1.000 ejemplares.	Validar aprobación en backend, no solo UI, y registrar firma/usuario/fecha.
SEC-039	Crítica	F12	Plantillas PDF	Inyección de código en plantilla HTML de justificante por usar sintaxis raw.	Sustituir raw por escaping, sanitizar campos y revisar todas las plantillas PDF/HTML.
SEC-040	Crítica	F12	Donaciones	Creación de donación por importe 0.	Validar importe mínimo > 0 y coherencia con premio disponible.
SEC-041	Crítica	F12	Donaciones	Overflow financiero mediante donación millonaria.	Límites máximos, validación de saldo y tipos numéricos seguros.
SEC-042	Crítica	F12	Donaciones	Donación asociada a participaciones inexistentes o no premiadas.	Validar existencia, titularidad, estado premiado y no cobrado antes de donar.
SEC-043	Crítica	F12	Donaciones / IDOR	Descarga de certificados de donación de otros usuarios.	Verificar propiedad del certificado y permisos por usuario/entidad.
SEC-044	Crítica	F12	Donaciones	Evasión de asignación de premio especial en participaciones marcadas para donar.	Incluir premios especiales en cálculo bloqueado e inmutable antes de confirmar donación.
SEC-045	Crítica	F12	Donaciones / Comisiones	Evasión de comisiones de pasarela al donar premio.	Calcular comisiones en servidor y bloquear manipulación.
SEC-046	Crítica	F12	Donaciones / Plazos	Donación fuera de plazo legal/lúdico de 3 meses.	Validar fecha de sorteo y caducidad antes de permitir donación.
SEC-047	Crítica	F12	Donaciones / Fiscal	Donaciones anónimas sin datos fiscales exigidos.	Exigir datos fiscales completos y trazabilidad del donante.
SEC-048	Crítica	F12	Donaciones / Certificados	Modificación manual del estado del certificado a emitido.	Estado de certificado solo por flujo autorizado, con firma y log.
SEC-049	Crítica	F12	Donaciones / IRPF	Evasión de retención IRPF en premios > 40.000 euros.	Aplicar retención automáticamente según umbral y bloquear manipulación.
SEC-050	Crítica	F12	Donaciones / Autorización	Vinculación de donación a entidad/ONG no autorizada.	Validar lista de entidades autorizadas y estado contable antes de donar.
SEC-051	Crítica	F12	Donaciones	Donaciones a peñas suspendidas contablemente.	Bloquear entidades suspendidas y mostrar motivo.

ID	Prioridad	Fase	Categoría	Problema detectado	Tarea de desarrollo
SEC-052	Crítica	F12	Donaciones / Auditoría	Modificación retroactiva de fecha de donación.	Hacer fecha inmutable tras creación y auditar cualquier cambio excepcional.
SEC-053	Crítica	F12	Códigos recarga	Códigos de recarga con importe negativo.	Validar importe > 0 en backend y restricción DB CHECK.
SEC-054	Crítica	F12	Códigos recarga	Generación de códigos sin saldo virtual suficiente.	Comprobar saldo disponible y reservar fondos antes de emitir código.
SEC-055	Crítica	F12	Contabilidad CSV	Importador CSV permite importes negativos.	Validar filas, rechazar importes negativos y generar informe de errores.
SEC-056	Crítica	F12	Comisiones	Comisiones de servicio negativas en códigos.	Validar comisión >= 0 y añadir restricción de base de datos.
SEC-057	Crítica	F12	IBAN / Remesas	Modificación externa de IBAN destino en liquidación Stripe/Imprenta.	Validar IBAN contra cuenta asociada y FK estricta; bloquear cambios no autorizados.
SEC-058	Crítica	F12	Códigos recarga	Modificación manual de cuenta destino del código a favor de terceros.	Vincular código a usuario/cuenta inmutable y validar ownership.
SEC-059	Crítica	F12	KYC	Bypass KYC en códigos superiores a 2.000 euros.	Exigir KYC verificado para umbrales altos y bloquear generación sin validación.
SEC-060	Crítica	F12	Conciliación bancaria	Cierre de caja con códigos prepago pendientes de conciliación.	Impedir cierre hasta conciliar códigos pendientes o marcarlos como excepción aprobada.
SEC-061	Crítica	F12	Fondos anulados	Códigos generados con fondos de transacciones anuladas.	Bloquear saldos de operaciones revertidas/anuladas y recalcular saldo disponible.
SEC-062	Crítica	F12	Stress / DB	Creación masiva de códigos temporales huérfanos agotando DB.	TTL, limpieza automática, límites por usuario/IP y transacciones atómicas.
SEC-063	Crítica	F12	Rate limit PDFs	Rate limit ausente en descarga de PDFs de actas de donaciones.	Rate limit, autorización y registro de descargas masivas.
SEC-064	Crítica	F12	Rate limit bypass	Bypass de rate limit con cabeceras X-Forwarded-For falsas.	Confiar solo en IP real del proxy confiable y normalizar cabeceras.
SEC-065	Crítica	F12	Idempotencia	Falta de idempotencia en webhooks bancarios de donación directa.	Idempotency key por evento bancario y deduplicación antes de modificar saldos.
SEC-066	Crítica	F13	SEPA	Permitir órdenes SEPA con importe negativo o cero.	Validar importe > 0 en backend y restricción DB.
SEC-067	Crítica	F13	SEPA / Mandato	Generar cobro SEPA sin mandato firmado y activo.	Verificar mandato activo antes de remesar y bloquear si falta.
SEC-068	Crítica	F13	IBAN	IBAN inválido y caracteres maliciosos en beneficiario SEPA.	Validar IBAN, normalizar campos y sanear caracteres.
SEC-069	Crítica	F13	Saldo	Sobregiro de remesas superior al saldo de premios.	Validar saldo disponible y reservar fondos al crear remesa.
SEC-070	Crítica	F13	XML / XXE	XXE en nombre/campos del deudor compilados en ISO 20022 XML.	Deshabilitar entidades externas, escapar XML y validar contra XSD seguro.
SEC-071	Crítica	F14	RBAC	Confirmación de transferencia por usuario no autenticado o sin rol admin.	Middleware RBAC en backend para aprobación manual.
SEC-072	Crítica	F14	Solvencia	Aprobar transferencia con pool de premios inferior al importe solicitado.	Validar fondos y bloquear operación si no hay saldo.
SEC-073	Crítica	F14	Integridad	Confirmar transferencia con participaciones ya cobradas en ventanilla.	Validar estado de cada participación y aplicar idempotencia.
SEC-074	Crítica	F15	Logs forenses	Borrado duro de logs forenses.	Hacer logs append-only/WORM, restringir DELETE y usar soft-delete controlado si aplica.
SEC-075	Crítica	F15	Logs forenses	Edición de trazas de log existentes.	Bloquear UPDATE en logs críticos y firmar/hash encadenado.
SEC-076	Crítica	F15	Máquina de estados	Spoofing de logs con transiciones imposibles.	Validar transiciones permitidas y rechazar estados incoherentes.
SEC-077	Crítica	F15	Logs / CRLF	Inyección CRLF en IP/User-Agent para falsear registros.	Normalizar/escapar cabeceras, eliminar CRLF y registrar IP desde proxy confiable.